

Third-Party Vendor Risk Assessment Methodology

Weighted vendor due diligence model for critical and data-sensitive service providers

Client / Entity	Sample Enterprise (fictional)
Prepared By	GRC Analyst Portfolio
Framework Basis	Risk-based vendor due diligence
Document Type	Methodology and Assessment Report
Version	1.0

Prepared by Gustavo do Carmo Lemes to demonstrate a practical, weighted approach to third-party and vendor risk evaluation, informed by real supplier assessment experience.

1. Methodology Overview

This project simulates a practical third-party risk assessment methodology for evaluating vendors that process sensitive information or support critical business operations. The model uses weighted domains that emphasize security governance, identity and access management, data protection, resilience, and incident response.

- Tier 1 vendors are those with access to regulated data, production workloads, or mission-critical services.
- Assessment scoring uses a weighted percentage model to distinguish acceptable, conditional, and unacceptable risk levels.
- Assessment outputs include due diligence findings, compensating control requirements, and review cadence recommendations.

2. Weighted Domains

Domain	Weight	Purpose
Governance and Policy	15%	Confirms leadership oversight, documented policies, and accountability
Identity and Access Management	20%	Validates MFA, least privilege, and access review practices
Data Protection	20%	Evaluates encryption, retention, and handling of confidential data
Vulnerability and Endpoint Security	15%	Assesses patching, secure configuration, and endpoint controls
Business Continuity and Resilience	15%	Measures backup, redundancy, and service continuity readiness
Incident Response and Notification	15%	Confirms response capability and contractual notification timelines

3. Sample Assessment Outcome

Vendor	Service Type	Tier	Assessment Result	Required Actions
NorthBridge Cloud Hosting	Production cloud infrastructure	1	Conditional Approval	Contractual breach-notification clause, annual pen test evidence, backup test results
Pulse Marketing Agency	Campaign services without regulated data	3	Approved	Review questionnaire annually
ClaimSync API Partner	Claims data processing integration	1	Conditional Approval	Complete MFA evidence review and encryption attestation